Segurança de Dados

MCTA023-17

Controle de Acesso e Autenticação de Usuário

Profª Denise Goya

Controle de Acesso

Duas partes do **controle de acesso**:

- **Autenticação**: (**quem** pode usar o sistema?)
  - Determinar se o acesso é permitido
  - Autenticação humano/máquina
  - Ou autenticação máquina/máquina

- Autorização: (tem **permissão** para fazer o quê?)
  - Uma vez que você tem acesso, o que você pode fazer?

Autenticação

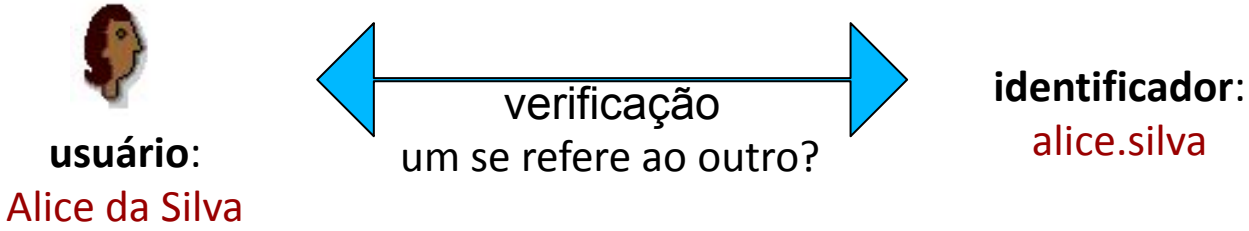
- Autenticação de mensagem:
  - visto em códigos de autenticação de msgs (**MAC**)
  - não ocorre em tempo real
  - autentica apenas uma mensagem por vez
- **Autenticação de usuário** ou entidade:
  - ocorre em tempo real
  - envolve **comunicação** entre participantes
  - somente depois que pelo menos um dos participantes for autenticado é que começa a troca de mensagens
  - a autenticação vale durante uma **sessão**, onde são trocadas várias mensagens

Foco desta aula

Autenticação

Envolve duas etapas:

- Identificação:
  - usuário ou entidade apresenta seu **identificador** no sistema (já previamente registrado)
- Verificação:
  - usuário/entidade apresenta ou gera informações que asseguram uma ligação entre o identificador e a entidade que tenta obter acesso



Autenticação

Pode se basear em:

- Algo que o indivíduo **conhece**:
  - ex: senha, PIN, respostas a perguntas pessoais
- Algo que o indivíduo **possui**:
  - ex: chave criptográfica armazenada ou gerada dinamicamente (smart cards, tokens)
- Algo que o indivíduo **é** (biometria estática):
  - ex: impressão digital, íris, face, palma da mão
- Algo que o indivíduo **faz** (biometria dinâmica):
  - ex: reconhecimento de voz, ritmo de digitação

Mecanismos de autenticação

Autenticação baseado em endereço

- Assume a identidade do emissor com base no endereço de rede do qual os pacotes são enviados.
- Usada no início do Unix (fazia sentido na época)
- Ameaças:
  - Falsificação de endereço de rede
  - Não autenticação de endereço origem

Mecanismos de autenticação

- Autenticação baseada em senha
  - Usa uma informação secreta (**senha**)
- Autenticação por desafio e resposta
  - Usa uma informação relacionada com um segredo
- Autenticação por protocolos de conhecimento-zero
  - Protocolos mais sofisticados
- Autenticação por biometria
  - Usa alguma informação fisiológica/comportamental relacionada com um indivíduo

Mecanismo de Autenticação por Senha

Senha

- Esquema de autenticação mais usado
- Esquema mais vulnerável e alvo de ataques
- **Problema:** a não aleatoriedade na seleção de senha (pode ser deduzida ou encontrada facilmente)

Senha

- A senha deve ser
  - fácil de lembrar, mas
  - difícil de adivinhar
- Tarefa difícil de se conseguir!

- Algumas perguntas
  - O que faz uma boa senha?
  - Onde a senha é armazenada, e de que forma?
  - Como é o processo de verificação da senha?

Senha: Como se escolhe?

Usuário costuma seguir um dos caminhos, para escolher, por exemplo, uma senha de 8 caracteres:

1. selecionar uma palavra de 8 caracteres
   - **vantagem**: mais fácil de lembrar (senhaBco)
   - **desvantagem**: ataque usando um **dicionário** tem alta probabilidade de encontrar a senha
2. palavra com escolha arbitrária de 8 caracteres
   - **vantagem**: mais difícil de adivinhar (z1tynpq3)
   - **desvantagem**: difícil de lembrar, às vezes o usuário precisa escrever a senha

Senha: Como se escolhe?

Dica 1: iniciais de uma **frase pessoal convertida**

"Minha experiência mais incrível foi aquela viagem em 2013" → memifave13 → ***mXm!f@ve1Ɛ***

Não pode ser muito curta!

Dica 2: frase sem sentido com pelo menos **16 caracteres** (mesmo sem caracteres especiais)

"BananaDinamarquesForaGelaAula"

Senha

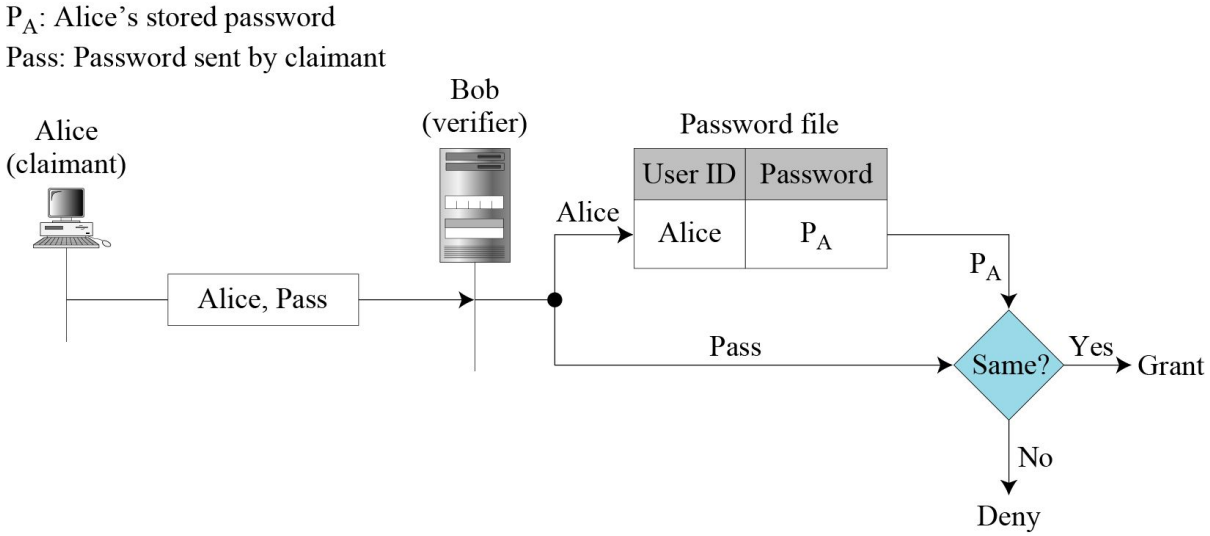
Como a senha deve ser

- transmitida?
- armazenada?

Senha em Claro

Modelo 1:

- Sistema mantém uma tabela de senhas
- O usuário envia uma senha e ID em texto claro para o sistema



Senha em Claro: Ataques

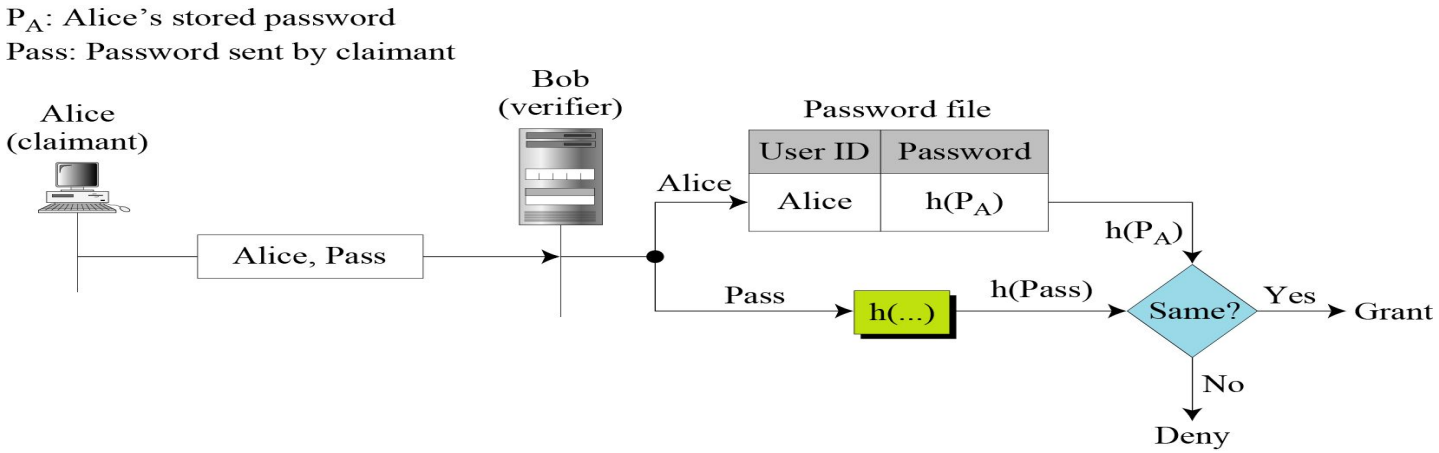
Modelo 1:

- **Escutas**: monitora a senha inserida pelo usuário (muitos sistemas por medida de segurança não mostra os caracteres digitados pelo usuário).
- **Roubar a senha**: o invasor tenta de forma física roubar a senha do usuário.
- **Acesso ao arquivo de senhas**: invasor pode atacar o arquivo de senhas. Com isso, pode ler os ID e senha e mudá-los.
- **Adivinhar/ Ataque de dicionário**: invasor pode tentar diferentes combinações para acessar (problema senhas curtas)

Hash da Senha

Modelo 2:

- Arquivo de senhas armazena o **hash das senhas**
- Quando o usuário envia ID e senha, o sistema cria hash e compara com o hash salvo no arquivo
- Como hash é não-inversível, torna-se impraticável adivinhar o valor da senha.



Hash da Senha: Ataques

Modelo 2:

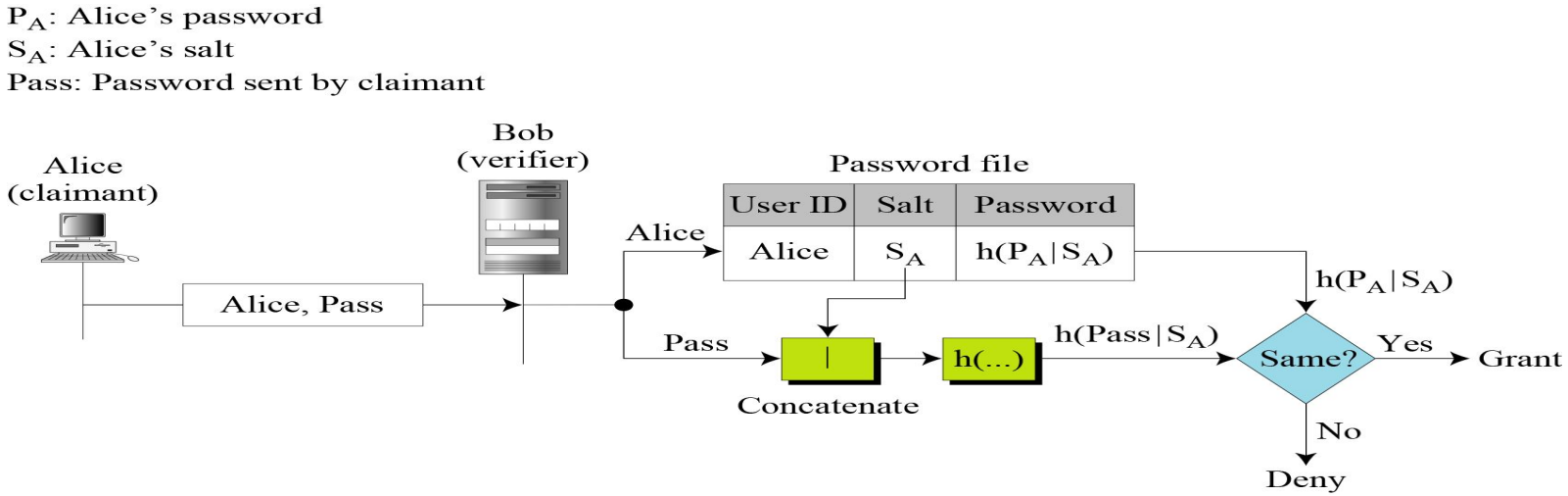
- **Ataque de Dicionário**: invasor pode lançar um ataque de "dicionário“, calculando o valor de hash de todas as palavras em um dicionário

Atualmente, não se deve usar este modelo na prática

Hash de Senha+Sal

Modelo 3:

- Quando a senha é criada, uma string aleatória, chamada de **sal** é concatenada à senha para serem aplicados à função hash:
  - ID, sal e hash são armazenados num arquivo.



Hash de Senha+Sal

Modelo 3:

- Quando o usuário quer ter acesso, o sistema extrai o sal e concatena com senha enviada, fazendo um hash com resultado e comparando com os dados da tabela.

- Ataque de dicionário se torna mais difícil

Usado atualmente, mas ataques de dicionário ou força bruta são consideravelmente viáveis com hardware+software dedicados (plataformas para execuções paralelizadas) para algoritmos antigos

Hash de Senha+Sal e Recomendação

PHC: Password Hashing Competition

- Concurso ocorrido entre 2013 e 2015

Argon2: vencedor e reconhecido como padrão recomendado

Outros 4 algoritmos receberam reconhecimento especial e também podem ser usados:

Catena, Lyra2, yescrypt e Makwa

Ferramentas de Quebra de Senhas

Ferramentas populares para quebrar senha:

- Password Crackers
- L0phtCrack and LC4 (Windows)
- John the Ripper (Unix), etc

Administradores devem usar ferramentas como essas para testar senhas fracas sob seus sistemas e, eventualmente, rever políticas de criação e atualização de senhas

Ataques por Repetição

Nos modelos anteriores

mesmo que a senha não seja transmitida em claro, alguém que intercepte as mensagens pode **repeti-las** em outra ocasião e se fazer passar pelo usuário.

Solução preliminar:

- enumerar os acessos
- senhas de uso único

Senha de Uso Único

No.	Pass.	No.	Pass.	No.	Pass.	No.	Pass.	No.	Pass.	No.	Pass.
1	7747	11	4893	21	8488	31	4699	41	0674	51	9446
2	7434	12	4706	22	6437	32	2434	42	0776	52	8494
3	3579	13	0851	23	6660	33	1310	43	1867	53	5278
4	8357	14	1220	24	5111	34	5393	44	8853	54	7603
5	4256	15	1786	25	0781	35	1825	45	6376	55	7700
6	9360	16	5504	26	4572	36	7485	46	3724	56	3205
7	6720	17	0970	27	7066	37	6950	47	9504	57	3864
8	0874	18	7557	28	6344	38	0632	48	8448	58	2926
9	3678	19	7864	29	3700	39	9096	49	4674	59	0975
10	0016	20	0687	30	3067	40	0513	50	1193	60	7840

Senha usada uma única vez

Modelo 1:

o usuário e o sistema entram em acordo sobre uma lista de senhas.

Modelo 2:

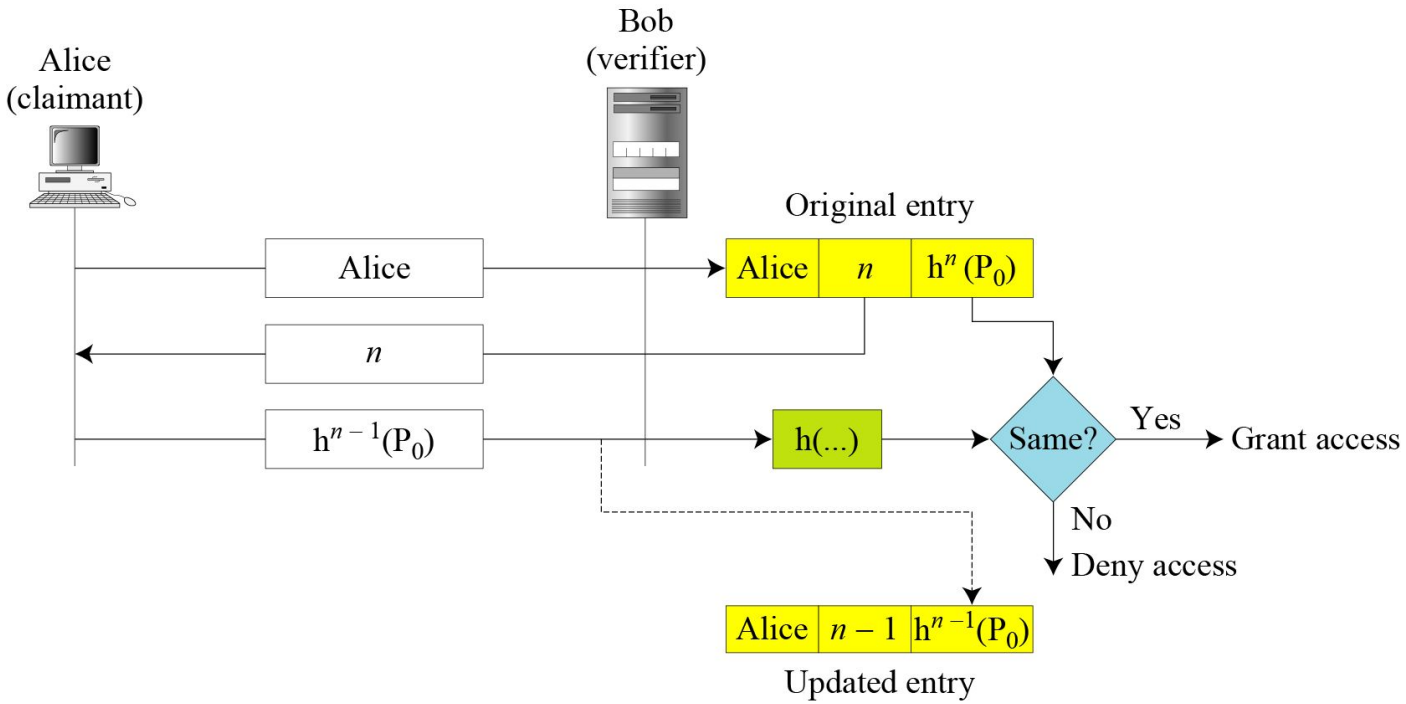
o usuário e o sistema entram em acordo para uma sequência de atualizações da senha

Modelo 3:

o usuário e o sistema criam uma sequência de atualizações usando uma função hash

$$h^n(x) = h(h^{n-1}(x)) \quad h^{n-1}(x) = h(h^{n-2}(x)) \quad \ldots \quad h^2(x) = h(h(x)) \quad h^1(x) = h(x)$$

Senha de Uso Único



$$h^n(x) = h(h^{n-1}(x)) \quad h^{n-1}(x) = h(h^{n-2}(x)) \quad \ldots \quad h^2(x) = h(h(x)) \quad h^1(x) = h(x)$$

Mecanismo de Autenticação por Desafio e Resposta

Autenticação

Pode se basear em:

- Algo que o indivíduo **conhece**:
  - ex: senha, PIN, respostas a perguntas pessoais
- Algo que o indivíduo **possui**:
  - ex: chave criptográfica armazenada ou gerada dinamicamente (smart cards, tokens)

Autenticação desafio-resposta

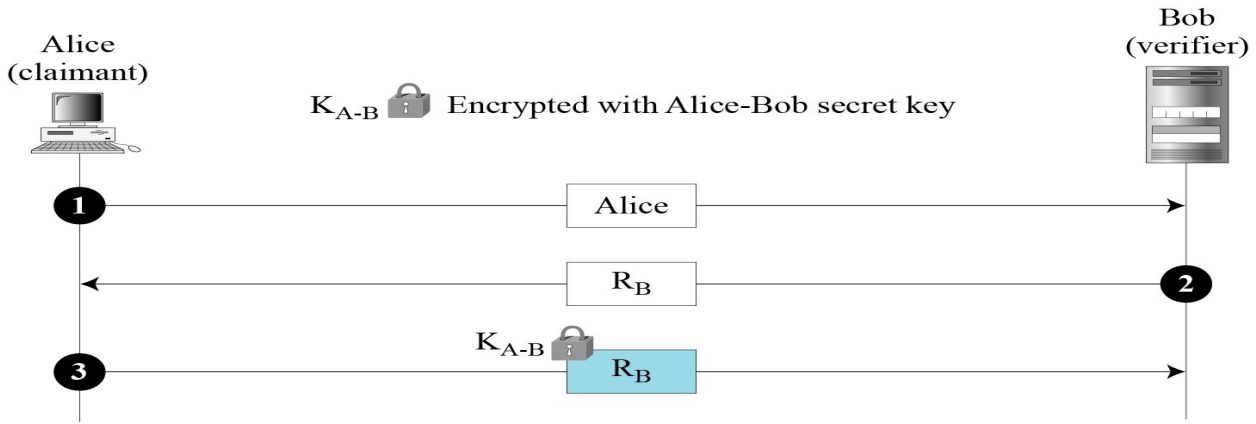
- Na autenticação por **senha**, o requerente prova sua identidade, mostrando o segredo que conhece: a senha
- Em autenticação **desafio-resposta**, o requerente prova que sabe um segredo sem enviá-lo.
  - Nem mesmo o hash do segredo é enviado
- o desafio é um valor que varia no tempo e é enviado pelo emissor (sistema)
- a resposta é o resultado de uma função aplicada sobre o desafio.

Autenticação desafio-resposta

Usando cifra de chave simétrica:

Modelo 1: O verificador envia um número aleatório de uso único (nonce: number used **only once**) para desafiar o requerente.

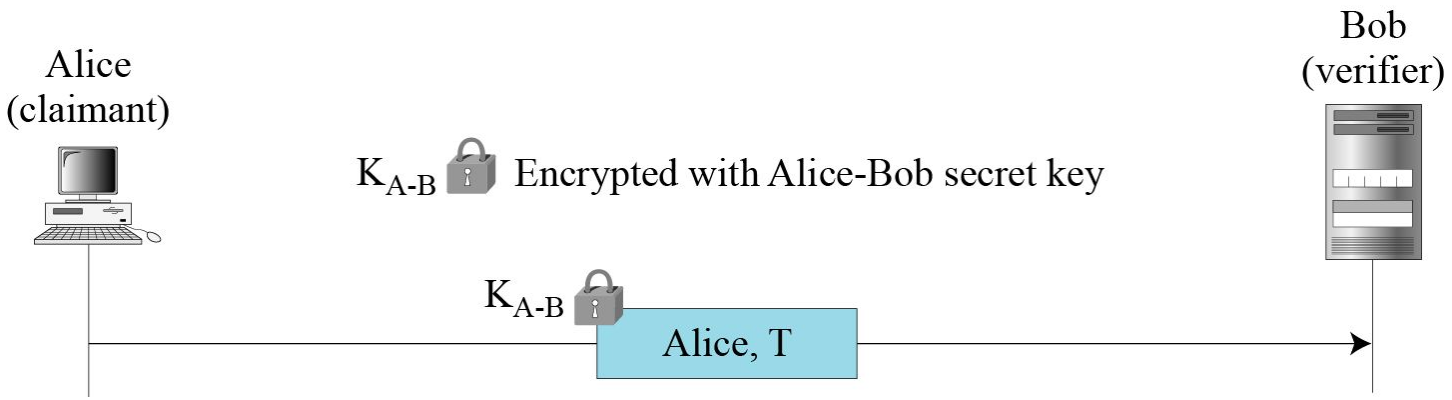
O requerente responde com a cifra do desafio sob a chave secreta compartilhada entre as duas partes.



Autenticação desafio-resposta

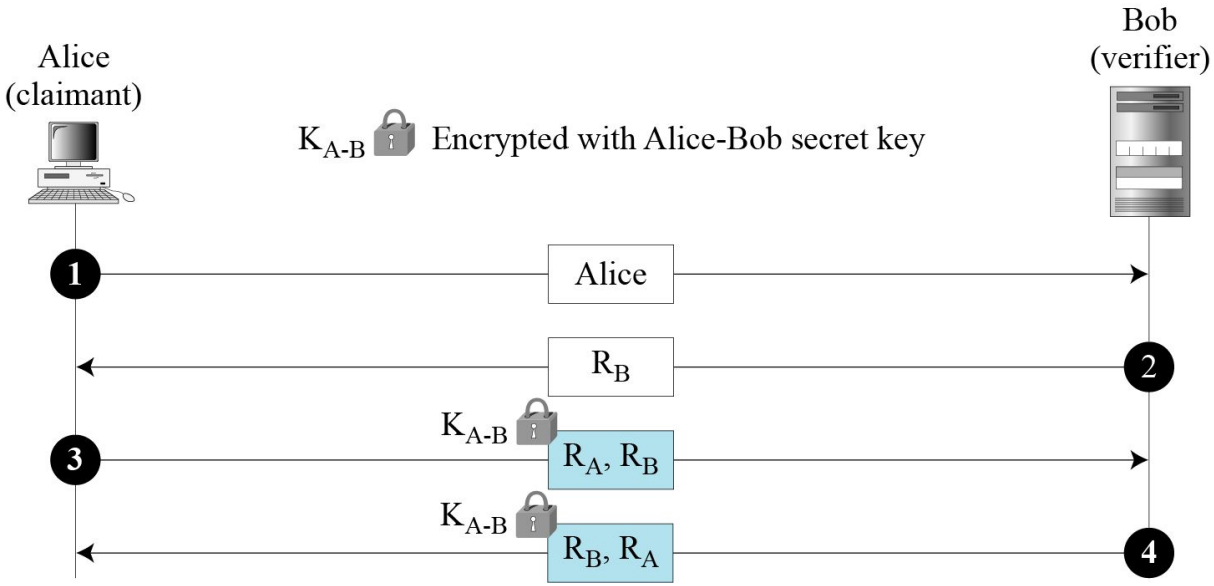
Modelo 2: o valor irá variar com o tempo por meio de um **timestamp** (data e hora).

Emissor e servidor devem estar sincronizados, sendo que o requerente deve conhecer a hora corrente.



Autenticação desafio-resposta

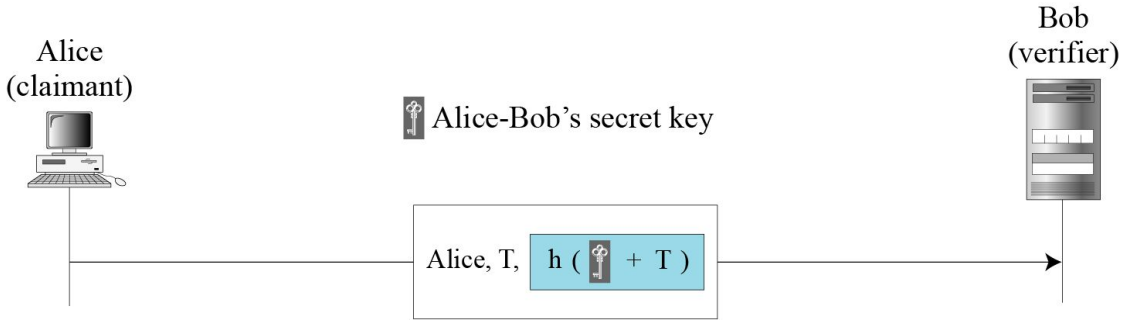
Modelo 3: as abordagens citadas anteriormente são unilaterais; para autenticação **mútua**:



Autenticação desafio-resposta

Em vez de usar cifra simétrica, usar autenticação **MAC**:

- preserva a integridade das mensagens do desafio/resposta e usa uma chave.
- timestamp é enviado em claro e operado com função hash
- o verificador recebe as informações e compara seu cálculo com o envido para autenticar o usuário

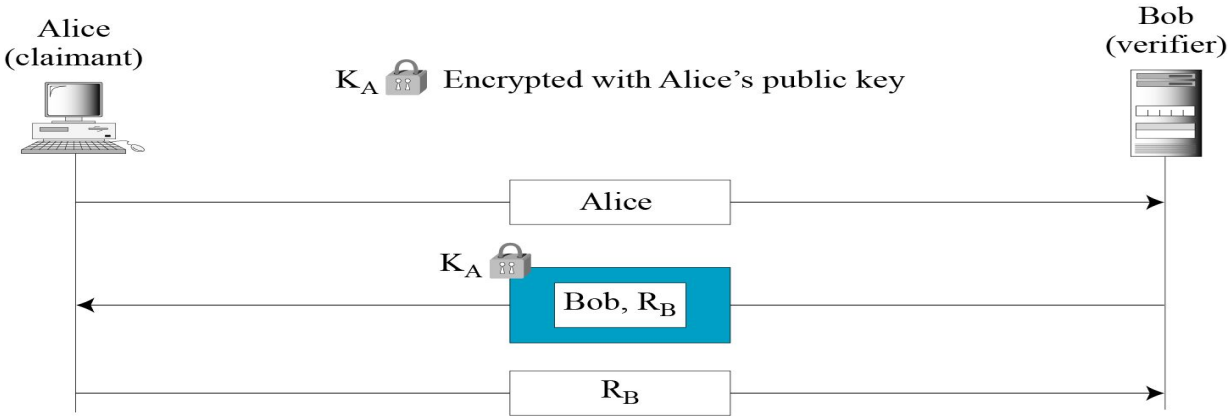


Autenticação desafio-resposta

Com criptografia assimétrica

Modelo 1: Verificador deve cifrar o desafio usando a chave pública do Requerente

Requerente deve decifrar o desafio (número aleatório, nonce) usando sua chave secreta e o envia para verificador → autenticação **unilateral**

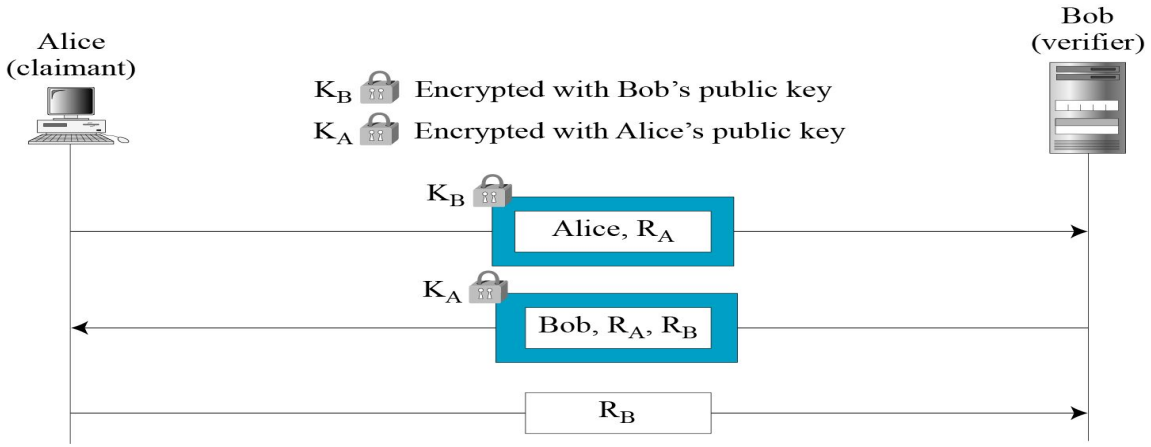


Autenticação desafio-resposta

Modelo 2: **duas chaves públicas** são usadas

Alice envia sua identidade e um nonce cifrado com a chave pública de Bob.

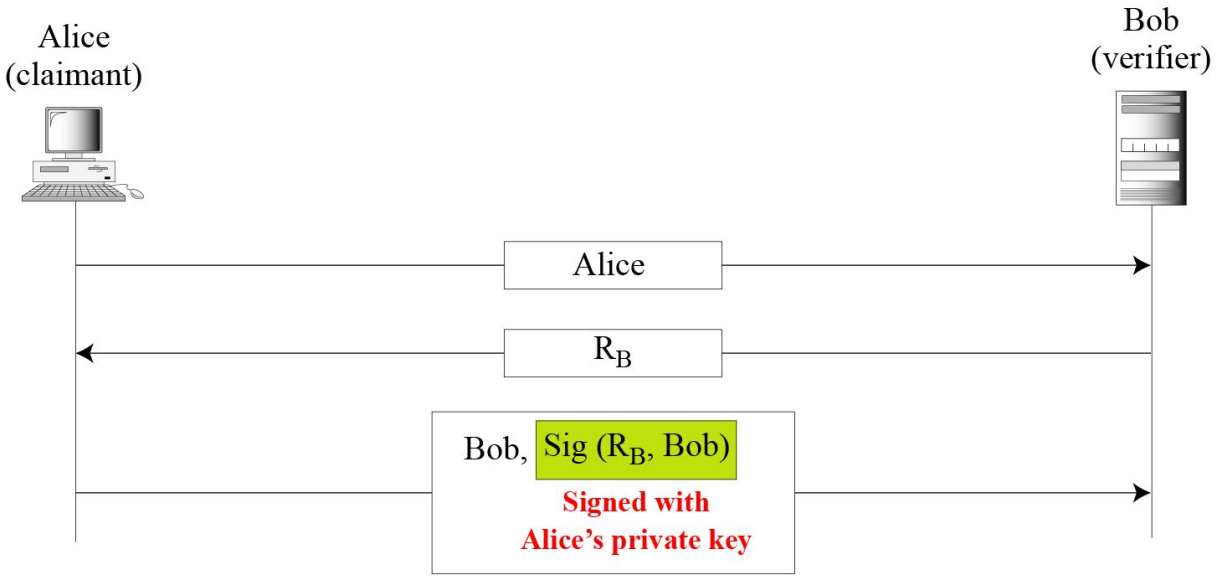
Bob responde com um nonce cifrado com a chave pública de Alice → autenticação **mútua**



Autenticação desafio-resposta

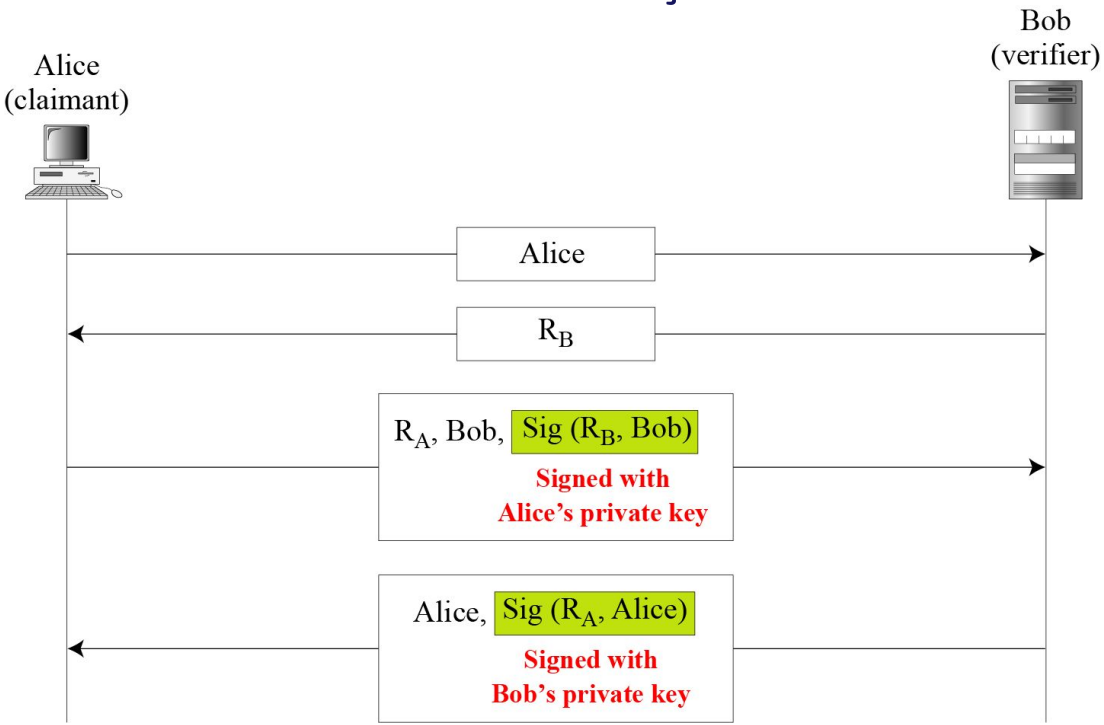
Assinatura digital (criptografia assimétrica)

Modelo1: Bob usa um desafio e Alice assina a resposta → autenticação **unilateral**



Autenticação desafio-resposta

Modelo 2: ambos assinam ⟶ autenticação **mútua**



Zero-Knowledge

Considere que você **não** confia no servidor e não quer entregar seu segredo a ele

- Autenticação por senha:
  - senha é compartilhada com o servidor
- Autenticação por Desafio-Resposta:
  - servidor pode não conhecer seu segredo, mas pode planejar certos desafios que vazam alguma informação sobre seu segredo
- Zero-Knowledge (conhecimento-zero):
  - garante autenticação sem vazamento de segredo

outra disciplina

Estudo Individual

Leituras Sugeridas

Tutorial para acesso a Livros via Cafe Capes, com login institucional UFABC:

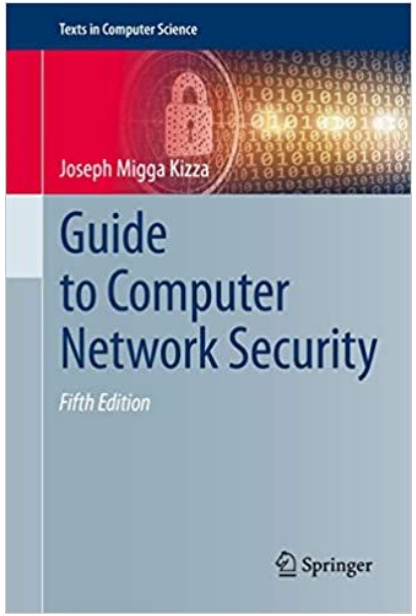
https://portal.biblioteca.ufabc.edu.br/images/docs/Orientacoes_para_o_acesso_remoto_via_CAFe.pdf

Logado, acesse:

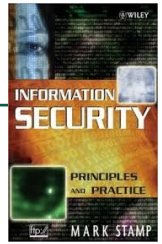
https://link-springer-com.ez42.periodicos.capes.gov.br/book/10.1007/978-3-030-38141-7

e leia Capítulo 10 de

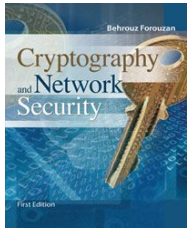
Joseph Migga Kizza - Guide to Computer Network Security (2020)



Outras Leituras Sugeridas

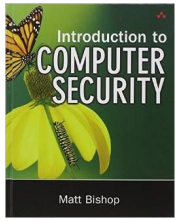


Stamp, M. Information Security: Principles and Practice, Wiley-Blackwell, 2005.



Behrouz A. Forouzan, Cryptography and Network Security, EISBN: 978-0-07-287022-0, Mc Graw Hill.

Goodrich, Tamassia. Introdução à Segurança de Computadores. Bookman, 2013.



Bishop, M. Introduction to Computer Security, Addison-Weslley, 2005.

Outras Leituras Sugeridas

Password Hashing Competition: https://password-hashing.net/

Fiorese, M. Uma Proposta de Autenticação de Usuários para Ensino a Distância, Capítulo 2. Dissertação de Mestrado, UFRGS, 2000. Disponível em http://penta.ufrgs.br/pesquisa/fiorese/autenticacaoeadindice.htm

Costa, Obelheiro, Fraga. Introdução à Biometria, Minicursos do SBSeg 2006. Disponível em

http://wiki.inf.ufpr.br/maziero/lib/exe/fetch.php?media=ceseg:2006-sbseg-mc3.pdf

Questões de Autoavaliação

(não precisa entregar)

Questões

1 - Por que é uma boa ideia usar as senhas de hash armazenados em um arquivo? O que é um "sal" e por que a técnica sal deve ser usada com a função hash?

2 – Quais são as vantagens de desvantagens de usar uma senha muito longa?

3- Defina as principais diferença entre senha fixa e senha one-time?

4 – Pesquise que modelo de armazenamento de senhas é adotado pelo Linux e o descreva com suas palavras.

Questões

5 – Discuta as diferenças entre os mecanismos de autenticação por biometria, comparando-os com os mecanismos por senha ou desafio-resposta.

6 – Discuta o uso e o funcionamento dos certificados digitais de chave pública junto a mecanismos de autenticação em sistemas. Pesquise e discuta 2 casos:

- servidores de Internet Banking
- e-CPF e e-CNPJ da Receita Federal

Dúvidas?